

DRAFT UNTIL ISSUED

BOARD REPORT · FY26 PRIVACY AND SECURITY REVIEW

भारत डेटा प्राइवेट लिमिटेड

Information security gap assessment

ISO 27001 2022

ASSESSMENT PERIOD

01 Apr 2026 to 30 Jun 2026

EVIDENCE CUT-OFF

15 Jul 2026

VERSION

v2 · 28 Sep 2026

SNAPSHOT

5f2c9e1a

Contents

01	How to read this report What the outcomes, risk levels and ratings mean	3
02	Executive summary The position in one page, then posture, domains, risk and decisions	5
03	Key observations The 3 highest-ranked approved findings	10
04	Remediation roadmap Initiatives by horizon and owner, effort against benefit, change since the last report	11
05	Annexure Methodology, requirement and evidence registers, Statement of Applicability	16

How to read this report

Every requirement gets one outcome, every gap gets a risk level, and each framework gets a score. This page explains all three.

1 · What we concluded for each requirement

■ Compliant	Met, and the evidence shows it.
■ Partially compliant	Met in part; a gap remains.
■ Non-compliant	Not met.
■ Not concluded	The evidence does not support a conclusion either way. Left out of scores, not counted as a failure.
■ Not applicable	Does not apply within the assessed scope.

2 · How serious each gap is

Critical Material regulatory or breach exposure. Act now.	High Significant exposure. Act this quarter.	Medium Moderate exposure. Plan within six months.	Low Limited exposure. Fix in the normal course.
---	--	---	---

3 · How a score becomes a rating

A framework's score is a weighted average of its domain scores, where a met requirement counts in full and a partly met one counts half. Scores are computed in code, never by AI, and never combined across frameworks.



Read a bar like this: the dark bar is the score (here 57%), the shaded bands are the rating thresholds behind it.

4 · How we rate each fix

Dimension	What it means
Priority ■■■	Set by the most serious gap the fix closes.
Effort ■■■	Our estimate: high is over 40 person-hours or a cross-team change.
Benefit ■■■	How much exposure the fix removes.

What this report does not do. It does not guess the likelihood of an incident, so there is no likelihood heat map; risk levels describe the severity of approved gaps only.

We assessed 79 requirements across 1 framework against evidence received up to 15 Jul 2026

Scope, the evidence we used and how every outcome was approved.

Scope

ISO 27001 2022

ISO 27001: 79 requirements in scope (Physical Controls excluded: single cloud-hosted office)

79
REQUIREMENTS

11

documents
reviewed

66

requirements
concluded

3

key observations

3

initiatives

4

open evidence
requests

ASSESSMENT PERIOD

01 Apr 2026 to 30 Jun 2026

EVIDENCE CUT-OFF

15 Jul 2026

Approach

1

Collect evidence

Documents, questionnaire answers and walkthrough notes received up to the cut-off, each stored by version with a fingerprint.

2

Assess and approve

For each requirement an outcome is proposed with the evidence it rests on. A consultant reviews the evidence and approves, edits or rejects every outcome.

3

Score and report

Scores are computed in code from approved outcomes only. Findings, owners and dates are agreed with management.

9 of 33 gaps are critical or high, and no framework is yet rated Compliant

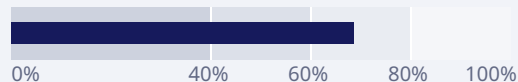
ISO 27001

■ Partially Compliant

69%

First report

no trend yet



IN BRIEF

Access governance and vulnerability management are the two areas that need attention; most other controls operate as described.

CRITICAL RISK 1 · ISO 27001

Access rights are never reviewed

Former staff and over-privileged users can reach customer data, the most common root cause of insider and credential-based breaches.

CRITICAL RISK 2 · ISO 27001

No defined cadence for patching technical vulnerabilities

Known, exploitable weaknesses on public systems are the leading entry point for ransomware.

HIGH RISK 3 · ISO 27001

Supplier security is not assessed before onboarding

Third-party compromise cannot be anticipated or contracted against.

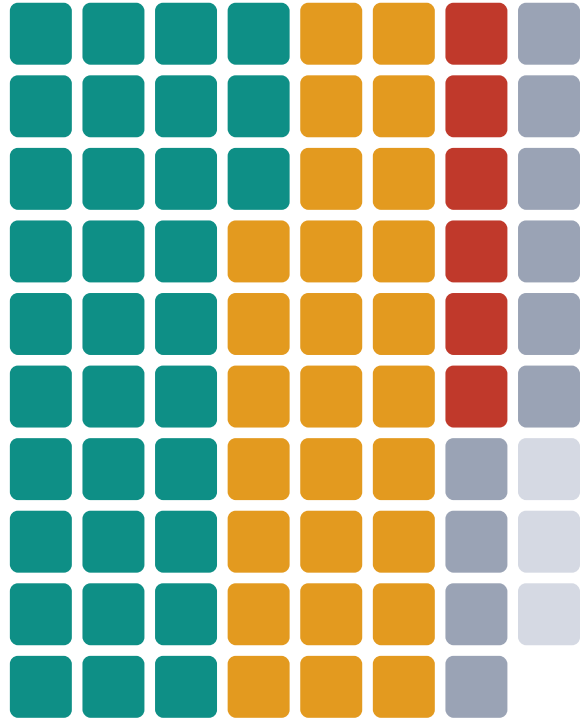
The board is asked to

1 Confirm the CISO as accountable owner for vulnerability management and set the patch SLA as a board-tracked KPI.

33 of 66 concluded requirements are met; 33 have gaps to close

Each square is one requirement. Counts can be read across frameworks; scores cannot, so each framework has its own grid.

ISO 27001 · 79 requirements



Columns of ten, filled from the top

69% Partially Compliant

Compliant	33	42%
Partially compliant	27	34%
Non-compliant	6	8%
Not concluded	10	13%
Not applicable	3	4%

Source: approved outcomes in report v2 (snapshot 5f2c9e1a), evidence cut-off 15 Jul 2026. Not-concluded requirements are left out of the score.

People Controls (60%) and Organizational Controls (65%) are the weakest areas

Domains are sorted weakest first. The dark bar is the domain score; the shaded bands behind it are the rating thresholds.

ISO 27001

69% · Partially Compliant

0% 40% 60% 80% 100%

People Controls

8 req · 4 gaps · 1 not concluded



60%

Organizational Controls

37 req · 18 gaps · 7 critical or high · 4 not concluded



65%

Technological Controls

34 req · 11 gaps · 2 critical or high · 5 not concluded



76%

Physical Controls

Out of scope

Source: approved outcomes in report v2 (snapshot 5f2c9e1a), evidence cut-off 15 Jul 2026. Thresholds: 80% Compliant, 60% Partially compliant, 40% Needs significant improvement.

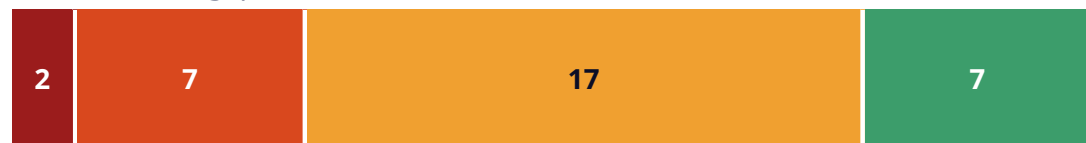
Organizational Controls holds 7 of the 9 critical or high gaps

Every approved gap carries one risk level. We count them; we do not estimate likelihood.



Gaps by risk level, per framework

ISO 27001 · 33 gaps



■ Critical ■ High ■ Medium ■ Low

Where the critical and high gaps sit

Organizational Controls [ISO 27001](#)

7

Technological Controls [ISO 27001](#)

2

Source: approved outcomes in report v2 (snapshot 5f2c9e1a), evidence cut-off 15 Jul 2026.

The board is asked to make 1 decision; 2 items need management attention

The decisions are risk decisions: each one closes an exposure named in this report.

1 Confirm the CISO as accountable owner for vulnerability management and set the patch SLA as a board-tracked KPI.

Recommended by Priya Sharma, Golden Advisory

Needs management attention

0

overdue actions

2

actions without an owner

10

requirements not
concluded

1 action has no target date.

15 requirements could not be concluded; 4 evidence requests are open.

3 key observations: 2 critical, 1 high (1 of 1)

The highest-ranked approved findings, the risk each creates and what we recommend.

+ Client + Golden Advisory ++ Shared

No.	Domain	Observation	Risk	Rating	Recommendation	Reference
R-03	+ Organizational Controls ISO 27001	Access rights are never reviewed No periodic review of user access is evidenced for production systems. 14 leaver accounts were still active at the cut-off.	Former staff and over-privileged users can reach customer data, the most common root cause of insider and credential-based breaches.	Critical	Run quarterly access recertification for production and customer-data systems with manager sign-off. Disable leaver accounts within 24 hours through an HR-triggered workflow and keep review evidence.	ISO 27001 Annex A.5.18; Annex A.5.3; Annex A.5.16; Annex A.5.11
R-04	+ Technological Controls ISO 27001	No defined cadence for patching technical vulnerabilities Scans run ad hoc; 23 critical CVEs older than 90 days were open on internet-facing hosts at the cut-off.	Known, exploitable weaknesses on public systems are the leading entry point for ransomware.	Critical	Adopt patch SLAs by severity (critical 15 days, high 30 days), scan internet-facing assets weekly, and report open critical vulnerabilities to the risk committee monthly.	ISO 27001 Annex A.8.8
R-07	+ Organizational Controls ISO 27001	Supplier security is not assessed before onboarding A supplier questionnaire exists but is not used; no supplier risk tiering is recorded.	Third-party compromise cannot be anticipated or contracted against.	High	Tier suppliers by data access, assess tier-1 suppliers before onboarding and annually, and record the risk decision in the supplier register.	DPDPA Section 8(2) ISO 27001 Annex A.5.19

04

REMEDIATION ROADMAP

2 of 3 initiatives fall in the next 90 days

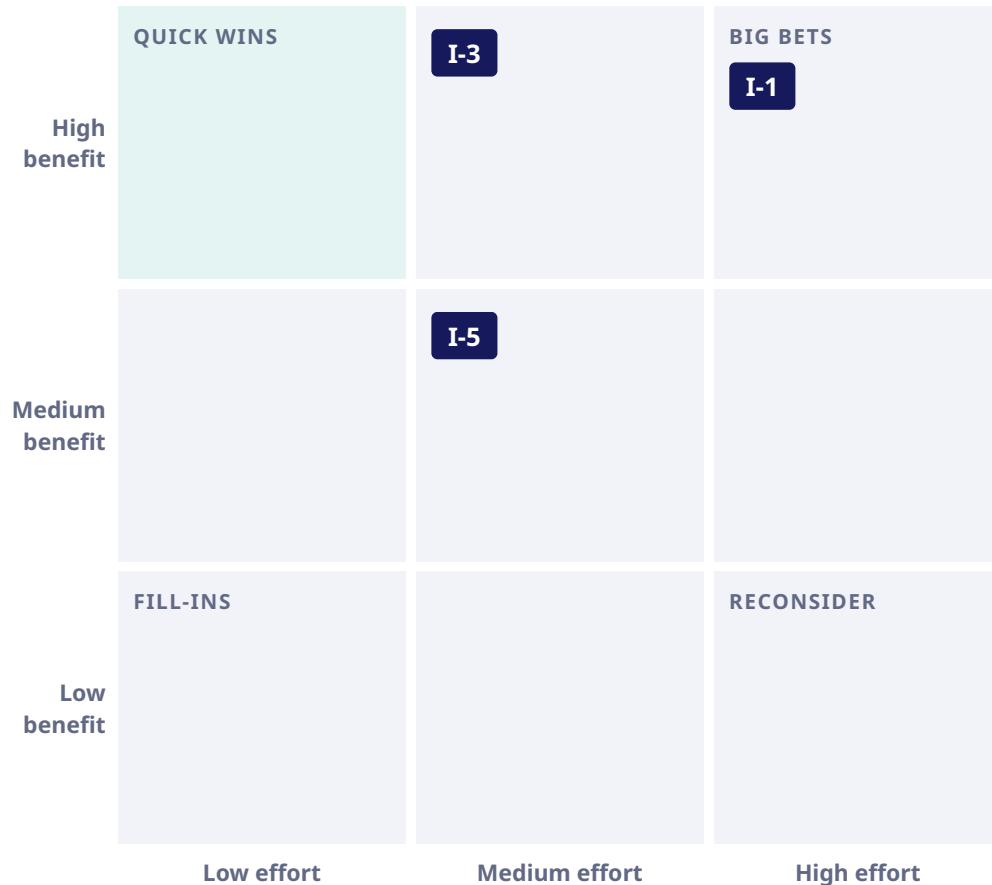
Each card is one initiative, placed by when it should be done and who does it.

OVERDUE past its target date

	Short term · within 90 days	Medium term · 91 to 180 days	Long term · after 180 days
+ Client	I-1 Establish role-based access and quarterly recertification Vikram Iyer (CISO) · 15 Sep 2026 · closes R-03 I-3 Introduce risk-based patch SLAs with board reporting Owner not set · 15 Nov 2026 · closes R-04		
++ Shared		I-5 Contract and assess processors and suppliers Anita Rao (DPO) · 28 Feb 2027 · closes R-07	

No quick wins: all 2 high-benefit initiatives need medium or high effort

Each initiative is placed by the effort it needs and the exposure it removes. Top left is where to start.

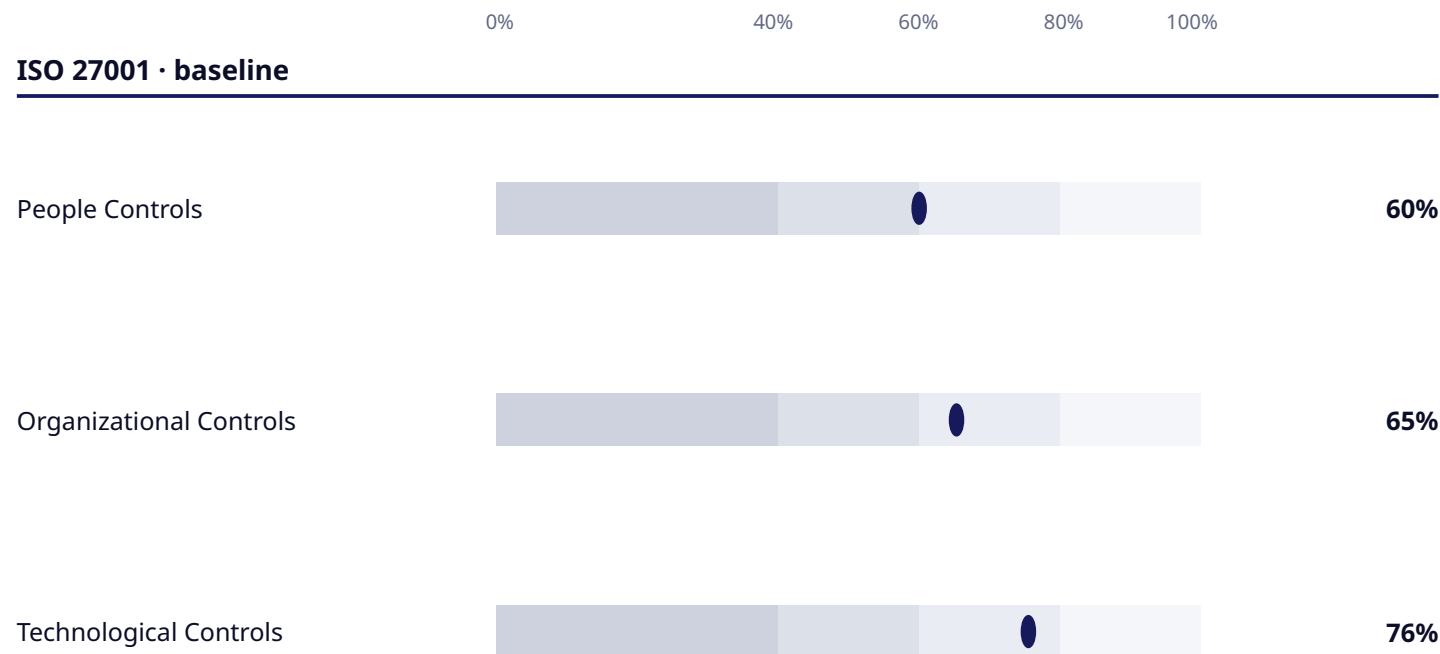


Benefit is the exposure an initiative removes; effort is our estimate of the work.

Ref	Initiative	Horizon	Priority	Effort	Benefit
I-1	Establish role-based access and quarterly recertification + Vikram Iyer (CISO) · closes R-03	Short term 15 Sep 2026			
I-3	Introduce risk-based patch SLAs with board reporting + Owner not set · closes R-04	Short term 15 Nov 2026			
I-5	Contract and assess processors and suppliers ++ Anita Rao (DPO) · closes R-07	Medium term 28 Feb 2027			

No earlier report to compare with

This is the first issued report for this client. These domain scores are the baseline the next report is measured against.



What the next report will show. For each domain, a grey dot for this report's score beside a dark dot for the new one, so movement reads at a glance, plus every requirement whose outcome changed.

10 requirements could not be concluded; 4 evidence requests are open

Not-concluded requirements are left out of scores, not counted as failures. The limits of this assessment follow.

10

not concluded · ISO 27001

Open evidence requests (v2)

RFI-01	Consent records export for July 2026	Required
RFI-02	Cross-border transfer register and destination list	Required
RFI-03	DPIA for the loan-underwriting model	Required
RFI-04	Last two backup-restore test reports	Recommended

The full list is in Annexure A2 (outcome "Insufficient evidence").

Limitations

This assessment does not include technical penetration testing, source code review, network security assessment, or any form of independent technical verification. Where the selected framework(s) include physical or environmental controls, findings on those controls are based on disclosed information and submitted documents, not on physical inspection or testing.

All findings reflect the information provided to the assessor at the time of the assessment. The assessor has not independently verified the accuracy or completeness of information provided. Material omissions or inaccuracies in disclosed information would affect the reliability of findings.

For requirements rated as Non-Compliant or Partially Compliant at a Critical or High risk level, independent verification by qualified legal counsel or a certified privacy professional (for INDIA DPDPA requirements), or by a qualified information security auditor (for ISO 27001), is strongly recommended before relying on those findings for regulatory submissions, board reporting, or contractual representations.

Most DPDPA 2023 obligations on Data Fiduciaries, and its penalty provisions, commence in mid-May 2027 (DPDP Rules 2025, G.S.R. 846(E)); findings against those obligations are a readiness assessment, not a determination of current non-compliance. Until then, obligations under the Information Technology Act, 2000, s.43A and the SPDI Rules, 2011 continue to apply and were not assessed.

Sign-off

Prepared and reviewed by the engagement team; the issue record lives in the version history.

PREPARED BY

Priya Sharma

Golden Advisory

REVIEWED BY

Ravi Menon

Golden Advisory

RELEASED FOR REPORTING

Priya Sharma

on 27 Sep 2026

ISSUE RECORD

Version history

Issuer, date and file fingerprint

Signature and date

Signature and date

Signature and date

Signature and date

Report version v2 · generated 28 Sep 2026 · snapshot 5f2c9e1a-4d7b-4e2a-9c3f-0b1d2e3f4a5b

Names are recorded as entered by the consultant; they are not verified sign-ins. This report is prepared solely for the use of the named organization. It should not be shared with third parties without the organization's explicit consent. Golden Advisory and the named organization are the intended recipients of this report.

05

Annexure

A1 Methodology

A2 Requirement register

A3 Evidence register

A4 Statement of Applicability summary

Methodology

This assessment evaluates compliance against the following framework(s): India DPDPA, ISO 27001, across 120 in-scope requirements.

Basis of Assessment:

Each in-scope requirement receives one conclusion. The analysis engine reviews the submitted documents and questionnaire responses and proposes an outcome with cited evidence. A consultant reviews the evidence and individually approves, edits or rejects every proposal. Only individually approved conclusions appear in this report; no outcome, score or finding is produced by the AI on its own.

Outcome Definitions:

- Compliant: the requirement is met and supported by evidence
- Partially Compliant: the requirement is met in part
- Non-Compliant: the requirement is not met
- Insufficient Evidence: the evidence provided does not support a conclusion either way
- Not Applicable: the requirement does not apply within the assessed scope

Scoring Basis:

Scores are computed only from conclusions a consultant has individually approved. Each approved outcome counts as follows: Compliant 100 points, Partially Compliant 50 points, Non-Compliant 0 points. Not Applicable and Insufficient Evidence are excluded from the scoring denominator. Insufficient Evidence is not treated as Non-Compliant; the number of requirements with insufficient evidence is reported next to each framework score. Requirements excluded at scoping are not scored. A framework is scored only when every in-scope requirement has an approved conclusion. Section scores are the average of their requirement points; domain and framework scores are weighted averages using the published weights below.

Framework Structure and Weights:

- India DPDPA (2023): 41 requirements in 6 domains. Domain weights: Obligations of Data Fiduciary 30%, Rights of Data Principal 20%, Special Provisions 20%, Consent Management (Detailed) 10%, Cross-Border Data Transfer 10%, Breach Notification 10%.

- ISO 27001 (2022): 93 requirements in 4 domains. Domain weights: Organizational Controls 35%, People Controls 15%, Physical Controls 15%, Technological Controls 35%.

Requirements are referenced by clause or control identifier for each selected framework; requirement descriptions are summarised for assessment purposes and do not reproduce the source standard. Scores are computed and reported independently for each framework; no score is combined across frameworks.

Rating Thresholds:

- 80-100%: Compliant
- 60-79%: Partially Compliant
- 40-59%: Needs Significant Improvement
- 0-39%: Non-Compliant

Risk Classification:

Each gap carries the risk level (Critical, High, Medium, Low) approved by the consultant, reflecting regulatory exposure, potential penalties under INDIA DPDPA and impact on affected individuals (for INDIA DPDPA), and likely impact on the confidentiality, integrity and availability of information (for ISO 27001). Remediation priority on each gap is derived from its approved risk level.

Disclaimer:

This assessment provides guidance based on the information and evidence provided and is not legal advice. Consult qualified legal counsel for definitive compliance determinations under INDIA DPDPA. For ISO 27001, it is not a certification audit; certification decisions rest with an accredited certification body or qualified assessor.

Requirement register (1 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A5.1	Policies for information security	Organizational Controls	 Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.2	Information security roles and responsibilities	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.17
ISO 27001	ISO.A5.3	Segregation of duties	Organizational Controls	 Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.8
ISO 27001	ISO.A5.4	Management responsibilities	Organizational Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.5
ISO 27001	ISO.A5.5	Contact with authorities	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.13
ISO 27001	ISO.A5.6	Contact with special interest groups	Organizational Controls	 Partially Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.21
ISO 27001	ISO.A5.7	Threat intelligence	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.21
ISO 27001	ISO.A5.8	Information security in project management	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.16
ISO 27001	ISO.A5.9	Inventory of information and other associated assets	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.5
ISO 27001	ISO.A5.10	Acceptable use of information and other associated assets	Organizational Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.28
ISO 27001	ISO.A5.11	Return of assets	Organizational Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.18
ISO 27001	ISO.A5.12	Classification of information	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26
ISO 27001	ISO.A5.13	Labelling of information	Organizational Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.24
ISO 27001	ISO.A5.14	Information transfer	Organizational Controls	 Non-Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.13

Requirement register (2 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A5.15	Access control	Organizational Controls	 Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.22
ISO 27001	ISO.A5.16	Identity management	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.27
ISO 27001	ISO.A5.17	Authentication information	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.8
ISO 27001	ISO.A5.18	Access rights	Organizational Controls	 Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	access-review-export.xlsx v1, Sheet 'Leavers', rows 2-15
ISO 27001	ISO.A5.19	Information security in supplier relationships	Organizational Controls	 Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.2
ISO 27001	ISO.A5.20	Addressing information security within supplier agreements	Organizational Controls	 Non-Compliant	High	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24
ISO 27001	ISO.A5.21	Managing information security in the ICT supply chain	Organizational Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.13
ISO 27001	ISO.A5.22	Monitoring, review and change management of supplier services	Organizational Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.8
ISO 27001	ISO.A5.23	Information security for use of cloud services	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.17
ISO 27001	ISO.A5.24	Information security incident management planning and preparation	Organizational Controls	 Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.25	Assessment and decision on information security events	Organizational Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.14
ISO 27001	ISO.A5.26	Response to information security incidents	Organizational Controls	 Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.30
ISO 27001	ISO.A5.27	Learning from information security incidents	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A5.28	Collection of evidence	Organizational Controls	 Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.16

Requirement register (3 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A5.29	Information security during disruption	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.7
ISO 27001	ISO.A5.30	ICT readiness for business continuity	Organizational Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	bcp-2024.pdf v1, whole
ISO 27001	ISO.A5.31	Legal, statutory, regulatory and contractual requirements	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.27
ISO 27001	ISO.A5.32	Intellectual property rights	Organizational Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.23
ISO 27001	ISO.A5.33	Protection of records	Organizational Controls	 Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.34	Privacy and protection of personal information	Organizational Controls	 Partially Compliant	High	Edited · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.18
ISO 27001	ISO.A5.35	Independent review of information security	Organizational Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.28
ISO 27001	ISO.A5.36	Compliance with policies, rules and standards	Organizational Controls	 Insufficient Evidence	Medium	Edited · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A5.37	Documented operating procedures	Organizational Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.10
ISO 27001	ISO.A6.1	Screening	People Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.25
ISO 27001	ISO.A6.2	Terms and conditions of employment	People Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.28
ISO 27001	ISO.A6.3	Information security awareness, education and training	People Controls	 Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A6.4	Disciplinary process	People Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.29
ISO 27001	ISO.A6.5	Responsibilities after termination or change of employment	People Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26

Requirement register (4 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A6.6	Confidentiality or non-disclosure agreements	People Controls	 Non-Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.21
ISO 27001	ISO.A6.7	Remote working	People Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.23
ISO 27001	ISO.A6.8	Information security event reporting	People Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.30
ISO 27001	ISO.A8.1	User endpoint devices	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.3
ISO 27001	ISO.A8.2	Privileged access rights	Technological Controls	 Partially Compliant	High	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.26
ISO 27001	ISO.A8.3	Information access restriction	Technological Controls	 Insufficient Evidence	High	Edited · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.4	Access to source code	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24
ISO 27001	ISO.A8.5	Secure authentication	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.6	Capacity management	Technological Controls	 Not Applicable	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.19
ISO 27001	ISO.A8.7	Protection against malware	Technological Controls	 Insufficient Evidence	Critical	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.8	Management of technical vulnerabilities	Technological Controls	 Non-Compliant	Critical	Approved · Priya Sharma, 24 Sep 2026	vuln-scan-summary.pdf v1, p.2
ISO 27001	ISO.A8.9	Configuration management	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A8.10	Information deletion	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.23
ISO 27001	ISO.A8.11	Data masking	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.24

Requirement register (5 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A8.12	Data leakage prevention	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.30
ISO 27001	ISO.A8.13	Information backup	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.14
ISO 27001	ISO.A8.14	Redundancy of information processing facilities	Technological Controls	 Insufficient Evidence	Medium	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.15	Logging	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.16	Monitoring activities	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.12
ISO 27001	ISO.A8.17	Clock synchronization	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.19
ISO 27001	ISO.A8.18	Use of privileged utility programs	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.12
ISO 27001	ISO.A8.19	Installation of software on operational systems	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.5
ISO 27001	ISO.A8.20	Networks security	Technological Controls	 Not Applicable	Critical	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.4
ISO 27001	ISO.A8.21	Security of network services	Technological Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.10
ISO 27001	ISO.A8.22	Segregation of networks	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.14
ISO 27001	ISO.A8.23	Web filtering	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.24
ISO 27001	ISO.A8.24	Use of cryptography	Technological Controls	 Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.15
ISO 27001	ISO.A8.25	Secure development life cycle	Technological Controls	 Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation

Requirement register (6 of 6)

Framework	Requirement	Title	Domain	Outcome	Risk	Decision	Evidence
ISO 27001	ISO.A8.26	Application security requirements	Technological Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.4
ISO 27001	ISO.A8.27	Secure system architecture and engineering principles	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	questionnaire-response.pdf v1, p.29
ISO 27001	ISO.A8.28	Secure coding	Technological Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.10
ISO 27001	ISO.A8.29	Security testing in development and acceptance	Technological Controls	 Partially Compliant	Medium	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.5
ISO 27001	ISO.A8.30	Outsourced development	Technological Controls	 Not Applicable	Medium	Approved · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.8
ISO 27001	ISO.A8.31	Separation of development, test and production environments	Technological Controls	 Insufficient Evidence	High	Approved · Priya Sharma, 24 Sep 2026	No supporting citation
ISO 27001	ISO.A8.32	Change management	Technological Controls	 Partially Compliant	Medium	Approved · Priya Sharma, 24 Sep 2026	access-control-policy.pdf v2, p.18
ISO 27001	ISO.A8.33	Test information	Technological Controls	 Partially Compliant	Low	Approved · Priya Sharma, 24 Sep 2026	isms-manual.pdf v4, p.10
ISO 27001	ISO.A8.34	Protection of information systems during audit testing	Technological Controls	 Compliant	Low	Edited · Priya Sharma, 24 Sep 2026	privacy-policy.pdf v3, p.18

Evidence register and Statement of Applicability

A3 · Evidence register

Document	Version	Added	Fingerprint	Cited
access-control-policy.pdf	v2	01 Jul 2026	cd072fd1a9b9	Yes
access-review-export.xlsx	v1	02 Jul 2026	03c3beb9183c	Yes
bcp-2024.pdf	v1	03 Jul 2026	5a83eec521a9	Yes
data-retention-policy.pdf	v1	04 Jul 2026	a159d6175aaa	Yes
incident-response-plan.docx	v2	05 Jul 2026	154f0237f3ea	Yes
isms-manual.pdf	v4	06 Jul 2026	9d25772e52dd	Yes
privacy-policy.pdf	v3	07 Jul 2026	b582f7695b7d	Yes
questionnaire-response.pdf	v1	08 Jul 2026	7bd7980b0a2b	Yes
vendor-contracts-index.xlsx	v2	09 Jul 2026	b231220b5006	Yes
vuln-scan-summary.pdf	v1	01 Jul 2026	3fec5195e1c5	Yes
board-minutes-q1.pdf	v1	02 Jul 2026	72466e7676a1	No

A4 · Statement of Applicability (ISO 27001 2022, 93 controls)

Theme	Implemented	Partially implemented	Not implemented	Not determined	Not applicable	Not assessed
Organizational Controls	15	14	4	4	.	.
People Controls	3	3	1	1	.	.
Physical Controls	.	.	.	.	.	14
Technological Controls	15	10	1	5	3	.

Excluded controls

Control	Justification
Annex A.8.6 Capacity management	Not relevant to the cloud-only operating model.
Annex A.8.20 Networks security	Not relevant to the cloud-only operating model.
Annex A.8.30 Outsourced development	No on-premises development; all development is outsourced under contract.

The full 93-control statement, with a justification column to complete, is in the workbook.